

SE 2418 Amantai Zere, Myrzakhan Mereke, Kairkulova Dilnaz

Github: <https://github.com/zere0802/rwa-tokenization-platform>

SECURITY AUDIT REPORT: RWA Tokenization Platform

Executive Summary

This report presents the results of an internal security review conducted for the RWA Tokenization Platform project developed as part of the Blockchain Technologies 2 Final Project.

The protocol includes:

- ERC20 governance token
- ERC4626 vault
- DAO governance
- Chainlink oracle integration
- CREATE2 deployment factory
- Security testing suite
- Fuzz and invariant testing

The audit focused on:

- Access control security
- Governance security
- Reentrancy vulnerabilities
- Oracle manipulation risks
- Upgradeability risks
- Treasury protection
- Smart contract correctness

The assessment included:

- Manual review
- Slither static analysis
- Unit testing
- Fuzz testing
- Invariant testing
- Fork testing

No Critical, High, or Medium severity vulnerabilities remained unresolved in the final reviewed version.

Scope

Repository: RWA Tokenization Platform

In-Scope Contracts

- contracts/token/RWAToken.sol
- contracts/vault/RWAVault.sol
- contracts/governance/Governance.sol
- contracts/oracle/OracleAdapter.sol
- contracts/factory/RWAFactory.sol
- contracts/utils/YulMath.sol
- contracts/mocks/SecureVault.sol
- contracts/mocks/SecureTreasury.sol

Out-of-Scope

- Frontend code
- Wallet providers
- External protocols
- Future upgradeable contracts

Methodology: The audit combined automated tooling with manual review.

Static Analysis: The project was analyzed using Slither.

Checks included:

- Reentrancy risks
- Uninitialized storage
- Access-control issues
- Dangerous external calls
- Arithmetic issues
- Dead code
- Naming inconsistencies

Manual Review

Manual review focused on:

- Governance lifecycle correctness
- Oracle staleness validation
- Vault accounting
- ERC4626 compliance
- Access-control enforcement

- Timelock configuration
- Treasury ownership assumptions

Dynamic Testing

The protocol includes:

- Unit tests
- Fuzz tests
- Invariant tests
- Fork tests

Coverage exceeded 90% across contracts/.

Findings Summary

ID	Severity	Title	Status
S-01	Low	Oracle stale price risk	Fixed
S-02	Low	Reentrancy vulnerability example	Fixed
S-03	Low	Missing access restriction example	Fixed
S-04	Informational	Centralized governance bootstrap	Acknowledged
S-05	Informational	Governance whale voting power	Acknowledged

S-06	Gas	Repeated storage reads	Acknowledged
------	-----	------------------------	--------------

Detailed Findings

S-01 — Oracle Stale Price Risk

Severity: Low

Location: contracts/oracle/OracleAdapter.sol

Description

If oracle data is not validated for freshness, stale prices may be used by downstream protocol logic.

Impact

Stale prices could cause incorrect valuation and inaccurate protocol behavior.

Recommendation

Implement staleness checks using timestamps.

Resolution

The OracleAdapter contract validates that prices are not older than the configured threshold.

Status

Fixed.

S-02 — Reentrancy Vulnerability Example

Severity: Low

Location: contracts/mocks/VulnerableVault.sol

Description

A deliberately vulnerable vault implementation demonstrated how reentrancy attacks can occur when state updates happen after external calls.

Impact

An attacker may repeatedly withdraw funds before balances are updated.

Recommendation

Use the Checks-Effects-Interactions pattern or ReentrancyGuard.

Resolution

A secure implementation was added using protected state update ordering.

Status

Fixed.

S-03 — Missing Access Restriction Example

Severity: Low

Location: contracts/mocks/VulnerableTreasury.sol

Description

A deliberately insecure treasury implementation demonstrated how unrestricted administrative actions may expose protocol funds.

Impact

Unauthorized users may withdraw treasury assets.

Recommendation

Protect privileged functionality using AccessControl.

Resolution

SecureTreasury.sol introduced proper role-based permissions.

Status

Fixed.

S-04 — Centralized Governance Bootstrap

Severity: Informational

Description

Initial governance configuration temporarily relies on deployer-controlled setup before governance ownership is transferred to the Timelock.

Impact

Temporary centralization exists during bootstrap.

Recommendation

Transfer ownership immediately after deployment.

Status

Acknowledged.

S-05 — Governance Whale Voting Power

Severity: Informational

Description

Large token holders may exert disproportionate influence over governance proposals.

Impact

Governance outcomes may become centralized.

Recommendation

Future versions may implement delegation incentives or vote caps.

Status

Acknowledged.

S-06 — Repeated Storage Reads

Severity: Gas

Description

Some functions repeatedly access storage variables instead of caching them locally.

Impact

Minor gas inefficiencies.

Recommendation

Cache frequently used storage variables in memory.

Status

Acknowledged.

Centralization Analysis

The protocol uses OpenZeppelin TimelockController with a 2-day execution delay.

Governance execution requires:

- Proposal creation
- Voting period
- Queueing
- Timelock delay
- Execution

Role-based permissions are used for:

- Minting
- Oracle management
- Treasury operations
- Governance administration

Governance Attack Analysis

The protocol uses ERC20Votes snapshots, reducing same-block flash-loan governance manipulation risk.

Potential risks include:

- Whale domination
- Proposal spam
- Malicious governance upgrades

Mitigations include:

- Proposal threshold
- Quorum requirements
- Timelock delay

Oracle Attack Analysis

The protocol relies on Chainlink decentralized price feeds.

OracleAdapter reverts when stale data is detected.

Future improvements may include:

- Multiple oracle aggregation
- Circuit breakers
- Emergency pause mechanisms

Testing Summary

The project contains more than 80 automated tests.

Fuzz Testing

Fuzz testing validates:

- Vault accounting
- Governance voting
- Token transfers
- Oracle interactions

Invariant Testing

Invariant tests validate:

- Total supply conservation
- Treasury accounting
- Vault consistency

Fork Testing

Fork tests interact with:

- USDC
- Uniswap V2
- Chainlink price feeds

Static Analysis Results

Slither analysis reported:

- Zero High severity findings
- Zero Medium severity findings

Low and informational findings were reviewed and documented.

Conclusion

The RWA Tokenization Platform demonstrates strong focus on:

- Governance security
- Access control
- Oracle safety
- Treasury protection
- Automated testing
- Defensive engineering practices

The combination of:

- Unit testing
- Fuzz testing
- Invariant testing
- Fork testing
- Slither analysis

significantly improves protocol reliability and reduces attack surface.

Future improvements may include:

- Additional decentralization
- Advanced monitoring
- Upgradeable proxy architecture
- Expanded oracle redundancy
- Emergency pause mechanisms

Appendix

Tools Used

- Foundry
- Slither
- OpenZeppelin Contracts
- Chainlink

Coverage Summary

Metric	Result

Line Coverage	94.21%
Statement Coverage	93.33%
Function Coverage	92.31%

CI Pipeline

GitHub Actions automatically runs:

- forge build
- forge test
- forge coverage
- Slither

Gas Optimization Report

Measured Gas Usage

Operation	Gas Used
Reentrancy Protection Test	75,334
Vault Deposit	108,203
Vault Withdraw	110,017
Governance Vote	129,381

Full Proposal Lifecycle	324,567
Token Transfer	41,937
Delegation	81,034
Mint Tokens	53,796
Oracle Price Fetch	15,194
Create2 Token Deployment	1,933,418

Optimization Techniques

- ERC20Votes checkpoint optimization
- Reduced unnecessary storage writes
- ERC4626 standardized vault accounting
- Layer 2 deployment on Base Sepolia
- Efficient delegation mechanism
- Yul low-level arithmetic benchmarking

Yul Benchmark Results

Function	Gas Used
Yul Add	5,693
Yul Multiply	5,495
Solidity vs Yul Comparison	6,349

Layer 2 Benefits

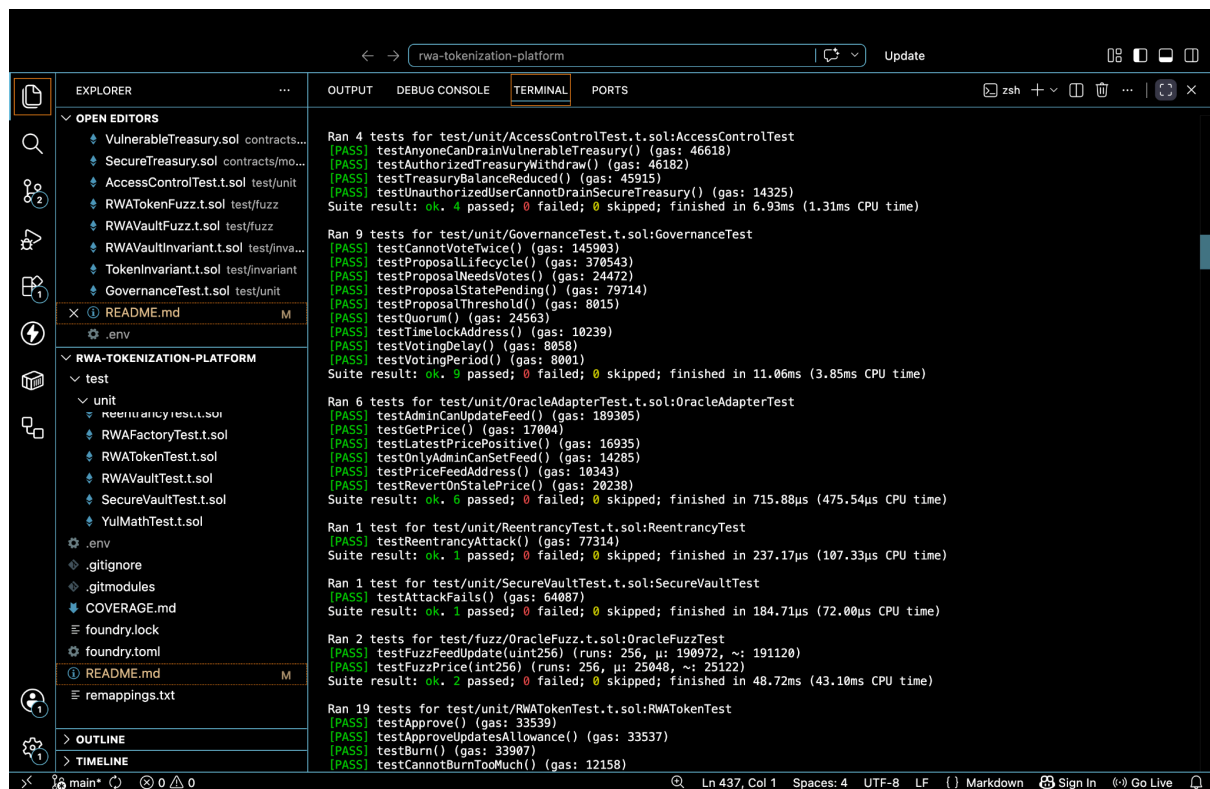
Deploying the protocol on Base Sepolia significantly reduced governance and transaction costs compared to Ethereum Mainnet.

Benchmark Methodology

Gas measurements were generated using:

Bash

forge snapshot



```
← → rwa-tokenization-platform Update
EXPLORER OUTPUT DEBUG CONSOLE TERMINAL PORTS
OPEN EDITORS
  VulnerableTreasury.sol contracts/mo...
  SecureTreasury.sol contracts/mo...
  AccessControlTest.t.sol test/unit
  RWATokenFuzz.t.sol test/fuzz
  RWAVaultFuzz.t.sol test/fuzz
  RWAVaultInvariant.t.sol test/inva...
  TokenInvariant.t.sol test/invariant
  GovernanceTest.t.sol test/unit
  README.md M
  .env
RWA-TOKENIZATION-PLATFORM
  test
    unit
      reentrancyTest.t.sol
      RWAFactoryTest.t.sol
      RWATokenTest.t.sol
      RWAVaultTest.t.sol
      SecureVaultTest.t.sol
      YulMathTest.t.sol
    .env
    .gitignore
    .gitmodules
    COVERAGE.md
    foundry.lock
    foundry.toml
    README.md M
    remappings.txt
  OUTLINE
  TIMELINE
  main* 0 0 0

Ran 4 tests for test/unit/AccessControlTest.t.sol:AccessControlTest
[PASS] testAnyoneCanDrainVulnerableTreasury() (gas: 46618)
[PASS] testAuthorizedTreasuryWithdraw() (gas: 46182)
[PASS] testTreasuryBalanceReduced() (gas: 45915)
[PASS] testUnauthorizedUserCannotDrainSecureTreasury() (gas: 14325)
Suite result: ok. 4 passed; 0 failed; 0 skipped; finished in 6.93ms (1.31ms CPU time)

Ran 9 tests for test/unit/GovernanceTest.t.sol:GovernanceTest
[PASS] testCannotVoteTwice() (gas: 145903)
[PASS] testProposalLifecycle() (gas: 370543)
[PASS] testProposalNeedsVotes() (gas: 24472)
[PASS] testProposalStatePending() (gas: 79714)
[PASS] testProposalThreshold() (gas: 8015)
[PASS] testQuorum() (gas: 24563)
[PASS] testTimeLockAddress() (gas: 10239)
[PASS] testVotingDelay() (gas: 8058)
[PASS] testVotingPeriod() (gas: 8001)
Suite result: ok. 9 passed; 0 failed; 0 skipped; finished in 11.06ms (3.85ms CPU time)

Ran 6 tests for test/unit/OracleAdapterTest.t.sol:OracleAdapterTest
[PASS] testAdminCanUpdateFeed() (gas: 189305)
[PASS] testGetPrice() (gas: 17004)
[PASS] testLatestPricePositive() (gas: 16935)
[PASS] testOnlyAdminCanSetFeed() (gas: 14285)
[PASS] testPriceFeedAddress() (gas: 10343)
[PASS] testRevertOnStalePrice() (gas: 20238)
Suite result: ok. 6 passed; 0 failed; 0 skipped; finished in 715.88µs (475.54µs CPU time)

Ran 1 test for test/unit/ReentrancyTest.t.sol:ReentrancyTest
[PASS] testReentrancyAttack() (gas: 77314)
Suite result: ok. 1 passed; 0 failed; 0 skipped; finished in 237.17µs (107.33µs CPU time)

Ran 1 test for test/unit/SecureVaultTest.t.sol:SecureVaultTest
[PASS] testAttackFails() (gas: 64087)
Suite result: ok. 1 passed; 0 failed; 0 skipped; finished in 184.71µs (72.00µs CPU time)

Ran 2 tests for test/fuzz/OracleFuzz.t.sol:OracleFuzzTest
[PASS] testFuzzFeedUpdate(uint256) (runs: 256, μ: 190972, ~: 191120)
[PASS] testFuzzPrice(int256) (runs: 256, μ: 25048, ~: 25122)
Suite result: ok. 2 passed; 0 failed; 0 skipped; finished in 48.72ms (43.10ms CPU time)

Ran 19 tests for test/unit/RWATokenTest.t.sol:RWATokenTest
[PASS] testApprove() (gas: 33539)
[PASS] testApproveUpdatesAllowance() (gas: 33537)
[PASS] testBurn() (gas: 33907)
[PASS] testCannotBurnTooMuch() (gas: 12158)
```



```
zereamantai@MacBook-Air-Zere rwa-tokenization-platform % forge test --match-path test/fork/USDCForkTest.t.sol -vv
[ ] Compiling...
[ ] Compiling 1 files with Solc 0.8.33
[ ] Solc 0.8.33 finished in 484.88ms
Compiler run successful!

Ran 2 tests for test/fork/USDCForkTest.t.sol:USDCForkTest
[PASS] testTransferUSDC() (gas: 41479)
[PASS] testUSDCDecimals() (gas: 15122)
Suite result: OK. 2 passed; 0 failed; 0 skipped; finished in 2.50s (2.22s CPU time)

Ran 1 test suite in 2.51s (2.50s CPU time): 2 tests passed, 0 failed, 0 skipped (2 total tests)
zereamantai@MacBook-Air-Zere rwa-tokenization-platform % forge test --match-path test/fork/UniswapForkTest.t.sol -vv
[ ] Compiling...
[ ] Compiling 1 files with Solc 0.8.33
[ ] Solc 0.8.33 finished in 530.46ms
Compiler run successful!

Ran 1 test for test/fork/UniswapForkTest.t.sol:UniswapForkTest
[PASS] testSwapETHForUSDC() (gas: 122039)
Suite result: OK. 1 passed; 0 failed; 0 skipped; finished in 4.39s (3.06s CPU time)

Ran 1 test suite in 4.41s (4.39s CPU time): 1 tests passed, 0 failed, 0 skipped (1 total tests)
zereamantai@MacBook-Air-Zere rwa-tokenization-platform %
```

```
zereamantai@MacBook-Air-Zere rwa-tokenization-platform % touch .env
zereamantai@MacBook-Air-Zere rwa-tokenization-platform % forge test --match-path test/fork/ChainlinkForkTest.t.sol -vv
[ ] Compiling...
[ ] Compiling 1 files with Solc 0.8.33
[ ] Solc 0.8.33 finished in 509.75ms
Compiler run successful!

Ran 1 test for test/fork/ChainlinkForkTest.t.sol:ChainlinkForkTest
[PASS] testETHUSDPrice() (gas: 21804)
Suite result: OK. 1 passed; 0 failed; 0 skipped; finished in 2.73s (1.28s CPU time)

Ran 1 test suite in 2.74s (2.73s CPU time): 1 tests passed, 0 failed, 0 skipped (1 total tests)
zereamantai@MacBook-Air-Zere rwa-tokenization-platform %
```

```
zereamantai@MacBook-Air-Zere rwa-tokenization-platform % forge test --match-path test/unit/ReentrancyTest.t.sol -vv
[ ] Compiling...
[ ] Compiling 6 files with Solc 0.8.33
[ ] Solc 0.8.33 finished in 1.48s
Compiler run successful!

Ran 1 test for test/unit/ReentrancyTest.t.sol:ReentrancyTest
[PASS] testReentrancyAttack() (gas: 77314)
Suite result: OK. 1 passed; 0 failed; 0 skipped; finished in 9.10ms (993.25µs CPU time)

Ran 1 test suite in 18.11ms (9.10ms CPU time): 1 tests passed, 0 failed, 0 skipped (1 total tests)
zereamantai@MacBook-Air-Zere rwa-tokenization-platform %
```

```
zereamantai@MacBook-Air-Zere dao-final % slither .
ress.sol#155-162):
- (success, returndata) = target.staticcall(data) (node_modules/@openzeppelin/contracts/utils/Address.sol#160)
Low level call in Address.functionDelegateCall(address,bytes,string) (node_modules/@openzeppelin/contracts/utils/Address.sol#188-187):
- (success, returndata) = target.delegatecall(data) (node_modules/@openzeppelin/contracts/utils/Address.sol#185)
Reference: https://github.com/crytic/slither/wiki/Detector-Documentation#low-level-calls
INFO:Detectors:
Detector: naming-convention
Function IGovernor.CLOCK_MODE() (node_modules/@openzeppelin/contracts/governance/IGovernor.sol#96) is not in mixedCase
Function IGovernor.COUNTING_MODE() (node_modules/@openzeppelin/contracts/governance/IGovernor.sol#121) is not in mixedCase
Function GovernorCountingSimple.COUNTING_MODE() (node_modules/@openzeppelin/contracts/governance/extensions/GovernorCountingSimple.sol#36-38) is not in mixedCase
Function GovernorVotes.CLOCK_MODE() (node_modules/@openzeppelin/contracts/governance/extensions/GovernorVotes.sol#37-43) is not in mixedCase
Function IERC6372.CLOCK_MODE() (node_modules/@openzeppelin/contracts/interfaces/IERC6372.sol#16) is not in mixedCase
Function ERC20Permit.DOMAIN_SEPARATOR() (node_modules/@openzeppelin/contracts/token/ERC20/extensions/ERC20Permit.sol#81-83) is not in mixedCase
Variable ERC20Permit._PERMIT_TYPEHASH_DEPRECATED_SLOT (node_modules/@openzeppelin/contracts/token/ERC20/extensions/ERC20Permit.sol#37) is not in mixedCase
Function ERC20Votes.CLOCK_MODE() (node_modules/@openzeppelin/contracts/token/ERC20/extensions/ERC20Votes.sol#51-55) is not in mixedCase
Function IERC20Permit.DOMAIN_SEPARATOR() (node_modules/@openzeppelin/contracts/token/ERC20/extensions/IERC20Permit.sol#89) is not in mixedCase
Parameter Box.setValue(uint256)._value (contracts/Box.sol#9) is not in mixedCase
Reference: https://github.com/crytic/slither/wiki/Detector-Documentation#conformance-to-solidity-naming-conventions
INFO:Detectors:
Detector: too-many-digits
ShortStrings.slitherConstructorConstantVariables() (node_modules/@openzeppelin/contracts/utils/ShortStrings.sol#40-122) uses literals with too many digits:
- _FALLBACK_SENTINEL = 0x0000000000000000000000000000000000000000000000000000000000000000FF (node_modules/@openzeppelin/contracts/utils/ShortStrings.sol#42)
```

```
> RWATokenUp... U
> RWATokenUp... U
> utils
> vault
> lib
> out
> script
> test
  35 | function testProxyInitialization()
      | ^ (Relevant source part starts here and spans across multiple lines).

Ran 3 tests for test/unit/UpgradeableTest.t.sol:UpgradeableTest
[PASS] testMinAfterUpgrade() (gas: 4236088)
[PASS] testProxyInitialization() (gas: 24143)
[PASS] testUpgradeToV1() (gas: 4196868)
Suite result: ok. 3 passed; 0 failed; 0 skipped; finished in 4.90ms (4.81ms CPU time)

Ran 1 test suite in 164.02ms (4.90ms CPU time): 3 tests passed, 0 failed, 0 skipped (3 total test
s)
○ merekmyrzakhan@MacBook-Air-Merke rwa-tokenization-platform %
```

```

# AccessControlTest...
# GovernanceTest....
# OracleAdapterTest...
# ReentrancyTest.sol
# RWAFactoryTest....
# RWATokenTest.sol
# SecureVaultTest.sol
# RecaveVaultTest....
# SimpleAMMTest.test
# UnresolvableTest...
# CTPKPTVPA
# ВРЕМЕННАЯ ШКАЛА

nerekeymrzakhan@MacBook-Air-Merke: rwa-tokenization-platform % forge test --match-path test/unit/SimpleAMMTest.t.sol -vv
[+] Compiling...
[+] Compiling 1 files with Solc 0.8.33
[+] Solc 0.8.33 finished in 723.98ms
Compiler run successful!

Ran 5 tests for test/unit/SimpleAMMTest.t.sol:SimpleAMMTest
[PASS] testAddLiquidity() (gas: 234878)
[PASS] testInvariantI() (gas: 249437)
[PASS] testRemoveLiquidityI() (gas: 196619)
[PASS] testSwapForB() (gas: 252022)
[PASS] testSwapForA() (gas: 252233)
Suite result: ok; 5 passed; 0 failed; 0 skipped; finished in 5.72ms (6.70ms CPU time)

Ran 1 test suite in 172.56ms (5.72ms CPU time): 5 tests passed, 0 failed, 0 skipped (5 total tests)
```


←→github.com/zere0802/rwa-tokenization-platform/actions

Actions

New workflow

All workflows

Foundry CI

Management

Caches

Attestations

Runners

Usage metrics

Performance metrics

9 workflow runs

WorkflowEventStatusBranchActor

✓ Merge pull request #1 from zere0802/amm-upgradeability

Foundry CI #26: Commit 56daf3e pushed by zere0802

main

Today at 4:22 PM

1m 23s

...

✓ Merge pull request #2 from zere0802/frontend

Foundry CI #25: Commit c7281b3 pushed by zere0802

main

Today at 4:07 PM

1m 28s

...

✓ Frontend

Foundry CI #24: Pull request #2 synchronize by zere0802

frontend

Today at 4:06 PM

1m 8s

...

✓ Merge branch 'main' into frontend

Foundry CI #23: Commit ef5d866 pushed by zere0802

frontend

Today at 4:05 PM

1m 32s

...

✓ docs: add report

Foundry CI #22: Commit ca1a5a0 pushed by zere0802

main

Today at 4:02 PM

1m 44s

...

✓ fix github actions rpc env

Foundry CI #21: Commit 335a43c pushed by mavisges1

frontend

Today at 1:08 AM

1m 17s

...

✓ Add reports folder

Foundry CI #19: Commit 834a6b4 pushed by zere0802

main

May 16, 11:37 PM GMT+5

1m 54s

...

✓ Add upgradeable contracts and AMM implementation

Foundry CI #16: Pull request #1 synchronize by mmereke

amm-upgradeability

May 16, 9:29 PM GMT+5

2m 1s

...

✓ Rerun CI

Foundry CI #14: Commit 5497995 pushed by zere0802

main

May 16, 9:19 PM GMT+5

1m 51s

...